CONFIDENTIAL **MOCK EXAM 2026**

GENERIC UNIVERSITY FINAL EXAMINATION

INSTRUCTIONS TO CANDIDATES

1. This question paper consists of two (2) parts: PART A (10 Questions)
   PART B (2 Questions)

2. Answer ALL questions in the Answer Booklet. Start each answer on a new page.

3. Do not bring any material into the examination room unless permission is given by the invigilator.

4. Please check to make sure that this examination pack consists of:

   i) the Question Paper
   ii) an Answer Booklet - provided by the Faculty

5. Answer ALL questions in English.

DO NOT TURN THIS PAGE UNTIL YOU ARE TOLD TO DO SO

This examination paper consists of 5 printed pages

PART A (80 MARKS)

QUESTION 1

a) State TWO (2) reasons why software is insecure, with particular reference to buffer overflows.

(2 marks)

b) Windows provides a rich set of security mechanisms, yet its complexity is often described as its own worst enemy. Explain six aspects of Windows security mechanisms, covering their purpose, the components involved, and the risks that arise from their complexity.

(6 marks)

QUESTION 2

a) Explain two characteristics of Trojan horse malware as described in the lecture, focusing on how it behaves and what harm it causes.

(2 marks)

b) Explain six techniques or behaviours by which malware such as viruses, worms and rootkits propagate themselves or conceal their activity on an infected system, as described in the lecture.

(6 marks)

QUESTION 3

a) Explain how a disclosure threat and a disruption threat each affect the confidentiality, integrity and availability of an information system, as described in the lecture.

(2 marks)

b) Discuss the Samy worm as a case study of a cross-site scripting attack, explaining how the malicious script was injected, how it spread between users, and what impact it had, as described in the lecture.

(6 marks)

QUESTION 4

a) State TWO (2) typical locations where network-based IDS sensors are placed in a network.

(2 marks)

b) Explain three preventive network security mechanisms that an organization can deploy to protect its network, describing what each mechanism does to control or secure traffic.

(6 marks)

QUESTION 5

a) List two formal security models named in the lecture and, for each, state the specific security concern it is designed to address.

(2 marks)

b) Discuss the access control structures used to implement access policies, covering the access control matrix, access control lists and capabilities, and explain the requirements such structures must satisfy.

(6 marks)

QUESTION 6

a) Explain how the chain of trust is established in the Trusted Computing architecture, referring to the role of the TPM and the measurements taken during boot.

(2 marks)

b) Describe the two primary system components of the Next Generation Secure Computing Base (NGSCB) and, for each component, state its role in the trusted platform.

(6 marks)

QUESTION 7

a) A biometric system performs identification and authentication through a sequence of stages. List TWO (2) stages that belong to the authentication stage of this process.

(2 marks)

b) State the definition of a biometric as given in the course, and state the two sectors into which today's biometric applications are categorised. Then state one example technology from each sector.

(6 marks)

QUESTION 8

a) Explain the difference between morals, ethics and laws as three forms of guidance for professional conduct in computer security.

(2 marks)

b) Refer to your answer in (a). Explain six requirements that a professional code of ethics and conduct, such as the ACM code, places on a computing professional working in computer security.

(6 marks)

QUESTION 9

a) Explain two password security controls that can be applied to password files and user accounts to reduce the risk of password compromise.

(2 marks)

b) State three motivations for adopting single sign-on, and state three design criteria that Kerberos satisfies as an SSO solution.

(6 marks)

QUESTION 10

a) State TWO (2) ways in which an intrusion detection system supports the detection and defence of a system against attacks, as described in the lecture.

(2 marks)

b) Compare the three security concepts of vulnerability, threat and attack as defined in the lecture, and explain how protection mechanisms are organised to counter threats to assets.

(6 marks)

PART B (20 MARKS)

QUESTION 1

a) Explain the goals that access control pursues and the role of the reference monitor in authorization, then describe how reference monitors relate to access control policies and where they may be deployed in a system.

(5 marks)

b) State the Chinese Wall model's simple security rule and its *-property, explain the type of policy the model represents, and describe how its permissions behave over time.

(5 marks)

QUESTION 2

A computing professional joins a group that has a documented set of acceptable behaviors, and the group defines which specific actions are appropriate or inappropriate. The group also publishes a code of ethics and professional conduct, but some members argue that such a code may not reflect the ethics of every member and is often not enforceable.

a) Explain five points about how a professional code of ethics, such as the ACM code, guides the ethical conduct of a computing professional, including what such a code is and the limitations of relying on it.

(5 marks)

b) Discuss five points on how privacy and organizational responsibility apply to the scenario, where the group publishes a code of ethics and professional conduct. Your answer should consider the ethical dimensions of handling personal information and the responsibilities the group and its members bear.

(5 marks)

END OF QUESTION PAPER